

Point it at your app. It tries to break it.

Open-source security scanning for the AI coding era. Web apps, APIs, Android builds and source — one command, one ranked fix list.

PRE-SEED

Ayamullah Khan & Kumar Shashwat Sandilya

ayamullahkhan04@gmail.com · fya.ayamk.in · github.com/ayam04/fya

● ● ● bash

```
$ pip install fya
$ fya scan https://myapp.com
```

```
detected  web app + REST API
running   58 checks
```

```
CRITICAL  AWS key in JS bundle
              static/app.js:42
              → move to env var, rotate
```

```
HIGH      SQL injection  /api/search
              → parameterize the query
```

CONFIDENTIAL

The people shipping fastest have the least security.

01

Real tools price them out

Snyk starts around \$500/mo. Veracode runs \$10K+/yr. Both assume a security engineer, a budget line and a procurement cycle. A two-person team has none of those.

02

Free tools cost a weekend

ZAP, sqlmap, MobSF, nuclei, testssl — five tools, five outputs, no shared report, no CI step. Setup alone is a Saturday, so it gets postponed indefinitely.

03

So the scan never happens

The API key stays in the JS bundle. The .git folder stays live. The search field stays injectable. You find out what broke when somebody else finds it first.

\$4.45M

average cost of a breach

64%

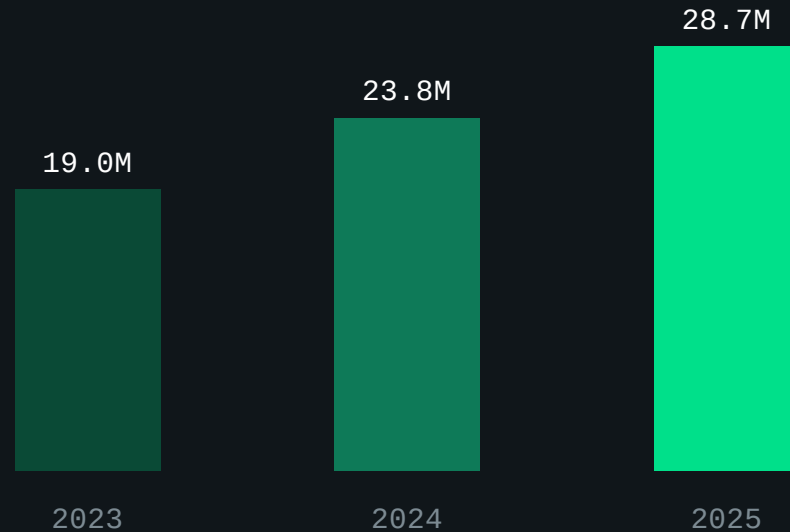
of secrets leaked in 2022
were still valid in 2026

Nobody is coming to clean this up. The tools that could are priced for the companies that already have a security team.

AI writes the code now. Nothing checks it.

New secrets exposed on public GitHub

millions of hardcoded credentials, per year



01 AI-assisted commits leak at 2× the rate

3.2% of commits co-authored by a coding agent leaked a secret, against a 1.5% GitHub-wide baseline.

02 The developer base just doubled overnight

Public commits rose 43% in 2025, and 54% of active developers made their first commit that year — a wave of builders with no security background.

03 Agents need a CLI, not a dashboard

fya already ships as a Claude Code skill, so an agent can scan the code it just wrote before the merge. Enterprise GUIs cannot be called by an agent.

The category is being created right now. Every month of AI-written code widens the gap fya closes.

GitGuardian, State of Secrets Sprawl 2026 (2023 figure derived from the reported 25% YoY increase into 2024)

One command, before you ship.

● ● ● fya · one command, four surfaces

```
$ fya scan https://myapp.com      # web + API
$ fya scan ./app-release.apk      # android
$ fya scan ./service --mode whitebox # source
```

```
✓ target detected automatically
✓ 58 checks · OWASP Top 10 + MASVS
```

```
CRITICAL Exposed AWS key
proof    GET /static/app.js:42
code     const AWS_KEY = "AKIA..."
fix       move to a server env var, rotate
ref      CWE-798 · OWASP A07:2021
```

```
scan complete  3 critical · 7 high · 12 med
report         fya-report.html · .pdf
```

■ Runs on your machine

No account, no agent, no portal, no seat. pip install and scan. Your source and your traffic never leave the laptop.

■ Proof, not a maybe

Every finding carries the request that triggered it and the line that fixes it, mapped to OWASP and CWE. Nothing to interpret.

■ Built for how code ships now

CLI and API first, with a Claude Code skill — so a human or an agent can gate a merge on a clean scan.

The whole product is one line a developer already knows how to type.

From 1,000 raw findings to a list you can act on.

01

DETECT

Fingerprints the target — web app, API, APK or source tree. No config file.



02

SCAN

58 checks mapped to OWASP Top 10 and MASVS, plus nuclei and sqlmap under the hood.



03

TRIAGE

The AI layer clusters duplicates, drops the noise and ranks what is actually exploitable here.



04

FIX

Each finding returns in plain English with the proof request and a one-line patch.

WITHOUT FYA

1,000+ findings, unranked, no context

-
- Five tools, five formats, no shared report
-
- So the developer closes the tab and ships

WITH FYA

A ranked shortlist — exploitable first

-
- One report across web, API, mobile and source
-
- So the developer fixes it before the merge

800 installs in the first 48 hours. Zero spend.

800

installs

first 48 hours on PyPI

300

unique developers

real people, not CI bots or mirrors

42

GitHub stars

developers bookmarking it to
come back

7

releases shipped

dual license live, revenue path
open

Nobody was marketed to.

No Product Hunt launch. No Show HN. No ads, no outbound, no list. Two days on PyPI and 300 developers went looking for a tool like this and found it. Demand for the category is not the question this round is testing.

STILL AHEAD OF US

Product Hunt launch

-
- Show HN
-
- First paid commercial licence
-
- CI/CD gate in GitHub Actions

Start with the underserved. Grow into the default.

TAM

\$6.4B

Application security testing tools, 2026. Reaches roughly \$24B by 2035 at a 15.7% CAGR.

SAM

\$1.2B

Developer-first security for teams with no security hire — bought on a card, not through procurement.

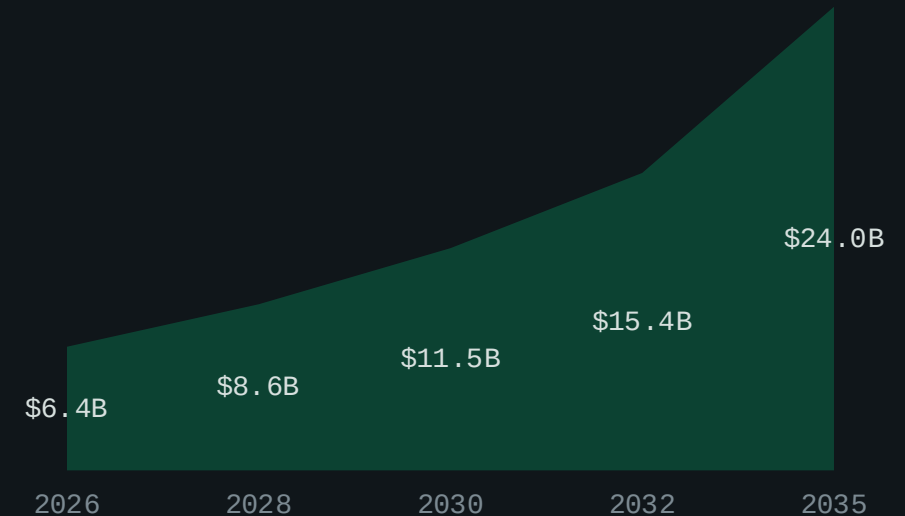
SOM

\$60M

Indie hackers, solo founders and teams of 2–10 shipping weekly. 300 of them already run fya.

Application security testing tools

global market, US\$ billions



Business Research Insights, AST Tools Market (2026–2035). SAM and SOM are directional; the wedge is validated by 300 active developers, not a top-down slice.

Everyone else picked one surface.

	Web DAST	API	Android	Source	Runs local	Free to start
Burp / enterprise DAST	✓	~	—	—	~	~
OWASP ZAP	✓	~	—	—	✓	✓
Snyk / Semgrep	—	—	—	✓	—	✓
MobSF	—	—	✓	~	✓	✓
fya	✓	✓	✓	✓	✓	✓

✓ full ~ partial — none

Every alternative covers one surface and assumes a security team on the other end. A solo founder shipping a web app with an API and an Android build has to run four tools and reconcile four reports — so they run none. fya is the only one that answers the whole question in one command.

The checks are open. The judgment is not.

01 Triage compounds with usage

Raw checks are public — anyone can fork nuclei. What cannot be forked is the record of which findings developers actually fixed and which they dismissed. Every scan sharpens the ranker; the ranker is the product.

02 The developer installs it, no one buys it

Bottom-up distribution through PyPI, GitHub and word of mouth. There is no procurement cycle to win, which is exactly why incumbents priced at \$500/mo cannot follow us down.

03 Agent-native from day one

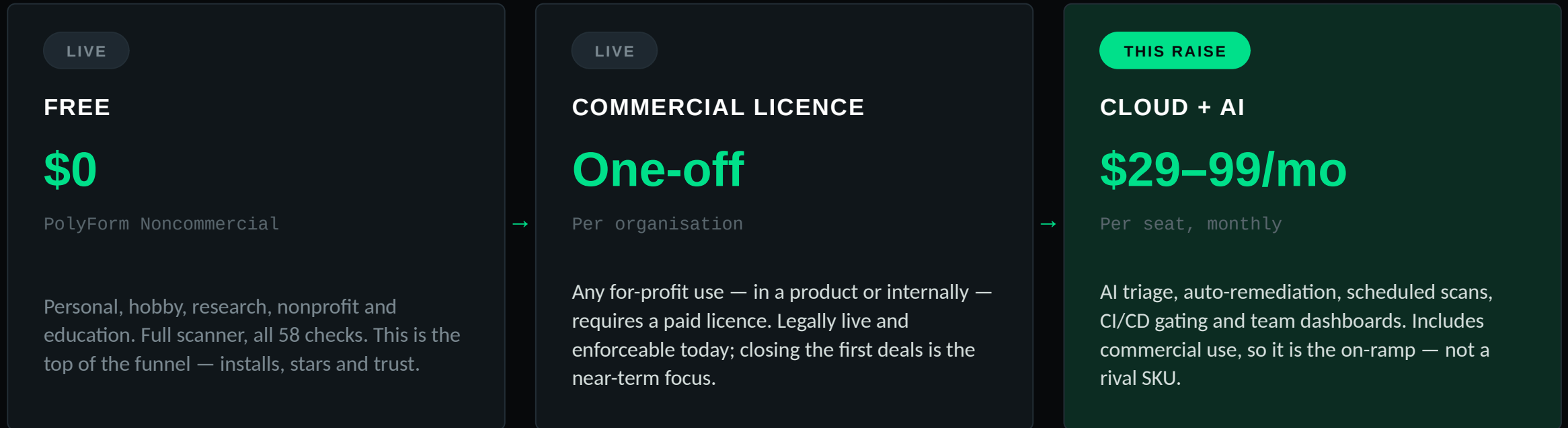
fya ships as a Claude Code skill. As coding agents write more of the code, the agent becomes the distribution channel — and it can only call tools with a CLI and an API.

04 Coverage is a year of work

Web, API, Android and source in one report, 58 checks mapped to OWASP and MASVS, validated against a bundled deliberately-vulnerable app. That is a year already spent.

"Why doesn't a frontier model just do this?" Because a model can read code, but it cannot reach your running app, replay the request that proves the bug, or learn from what your team chose to fix. fya is the harness around the model, and the harness is where the data accrues.

Free to install. Paid to depend on.



Snyk \$500+/mo
\$29/mo

Veracode \$10K+/yr

fya from

Same question answered, one twentieth of the price, no seat minimum and no procurement.

The tool does the selling.

LAND

The scanner spreads on its own

pip install, GitHub, and a Claude Code skill that agents pull in. Developers run it on their own apps. Zero sales motion, zero CAC.

Product Hunt launch

-
- Show HN
-
- Dev community seeding



EXPAND

A scan that finds three real bugs sells itself

The free scan surfaces genuine vulnerabilities. The developer now wants the fixes, the monitoring and a CI gate. That is the \$29/mo upgrade.

In-CLI upgrade prompt

-
- CI/CD gate
-
- Team dashboard



COMPOUND

Every user makes the next scan sharper

More scans train better triage. Better triage means fewer false positives. Fewer false positives pull in the next developer. A wrapper cannot copy this.

Triage feedback loop

-
- Word of mouth
-
- Compliance reporting

Target: 10% of active free users converting to a paid tier.

Two builders. Shipped before they raised.



AYAMULLAH KHAN

CO-FOUNDER · PRODUCT & SCANNER

Built the fya engine and all 58 OWASP Top 10 / MASVS-mapped checks, validated against a bundled deliberately-vulnerable app, plus the orchestration layer, the CLI and the dual-licence model.

AI engineer across GenAI and agentic systems. Data Science, IIT Madras and Manipal University Jaipur.

github.com/ayam04



KUMAR SHASHWAT SANDILYA

CO-FOUNDER · AI & CLOUD

Owns the hosted Cloud engine and the AI finding-triage and auto-remediation product this raise funds — the layer that turns raw coverage into a ranked fix list.

AI developer and data scientist across GenAI and machine learning.

kss04.me

Both founders are currently enrolled students. The scanner was built, licensed and installed 800 times before we asked anyone for money.

From a CLI to the security layer.

NOW

CLI scanner, live

58 OWASP / MASVS checks

-
- 800 installs, 300 developers
-
- Dual licence, revenue path open
-
- Claude Code skill shipped
-
- PDF and HTML reports

6-12 MONTHS

Cloud + AI

Hosted scanning platform

-
- AI triage + auto-remediation
-
- CI/CD, Slack and GitHub hooks
-
- Scheduled scans and API access
-
- First recurring subscriptions

12-24 MONTHS

Security platform

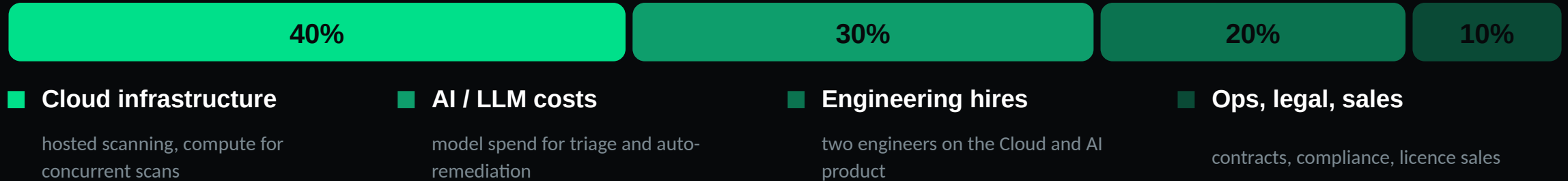
Posture tracked over time

-
- Trend analysis + compliance
-
- SOC 2 / PCI DSS / HIPAA reports
-
- Multi-repo, multi-team rollups
-
- The team's system of record

The security layer every fast-moving team runs by default, on every surface they ship.

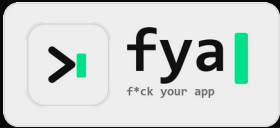
\$750K to turn 800 installs into recurring revenue.

₹7.2 Cr · within a \$500K–\$1M range · roughly 12 months of runway · compute and model spend scale only as paid usage grows



WHAT \$750K BUYS IN 12 MONTHS

- **Cloud + AI platform shipped**
hosted scanning and AI triage in general availability, not beta
- **Installs into the tens of thousands**
with repeat-scan usage tracked per developer, not just downloads
- **First recurring revenue**
for-profit teams moved from a one-off licence to a monthly subscription
- **A repeatable free-to-paid funnel**
conversion measured and predictable — ready to pour fuel on at seed



Security stopped being optional the day AI started writing the code.

fya is already installed on 300 developers' machines. This round makes it the thing they pay for.

Point it at your app. It tries to break it.

LET'S TALK

FOUNDERS

Ayamullah Khan
Kumar Shashwat Sandilya

EMAIL

ayamullahkhan04@gmail.com

PRODUCT

fya.ayamk.in

SOURCE

github.com/ayam04/fya

LINKEDIN

linkedin.com/in/ayam04